# Phishing Email Analysis Report

*Forensic Investigation of Sample-996.eml*

Analysis Date: April 13, 2026 | Dataset: Phishing Pot (rf-peixoto/phishing_pot)

## 1. Executive Summary

This report documents the forensic analysis of a phishing email (sample-996.eml) sourced from the Phishing Pot open-source dataset. The email was examined within an isolated Ubuntu virtual machine environment using Mozilla Thunderbird for email rendering and Mousepad as a raw header viewer. The investigation covered email authentication mechanisms, header analysis, sender infrastructure, and embedded malicious URLs.

The email impersonates Binance, a major cryptocurrency exchange, to deceive recipients into participating in a fraudulent ARB (Arbitrum) token airdrop. The campaign leverages social engineering tactics, urgency cues, and a spoofed sender identity to harvest user credentials or redirect victims to attacker-controlled infrastructure.

## 2. Analysis Environment & Dataset

### 2.1 Lab Setup

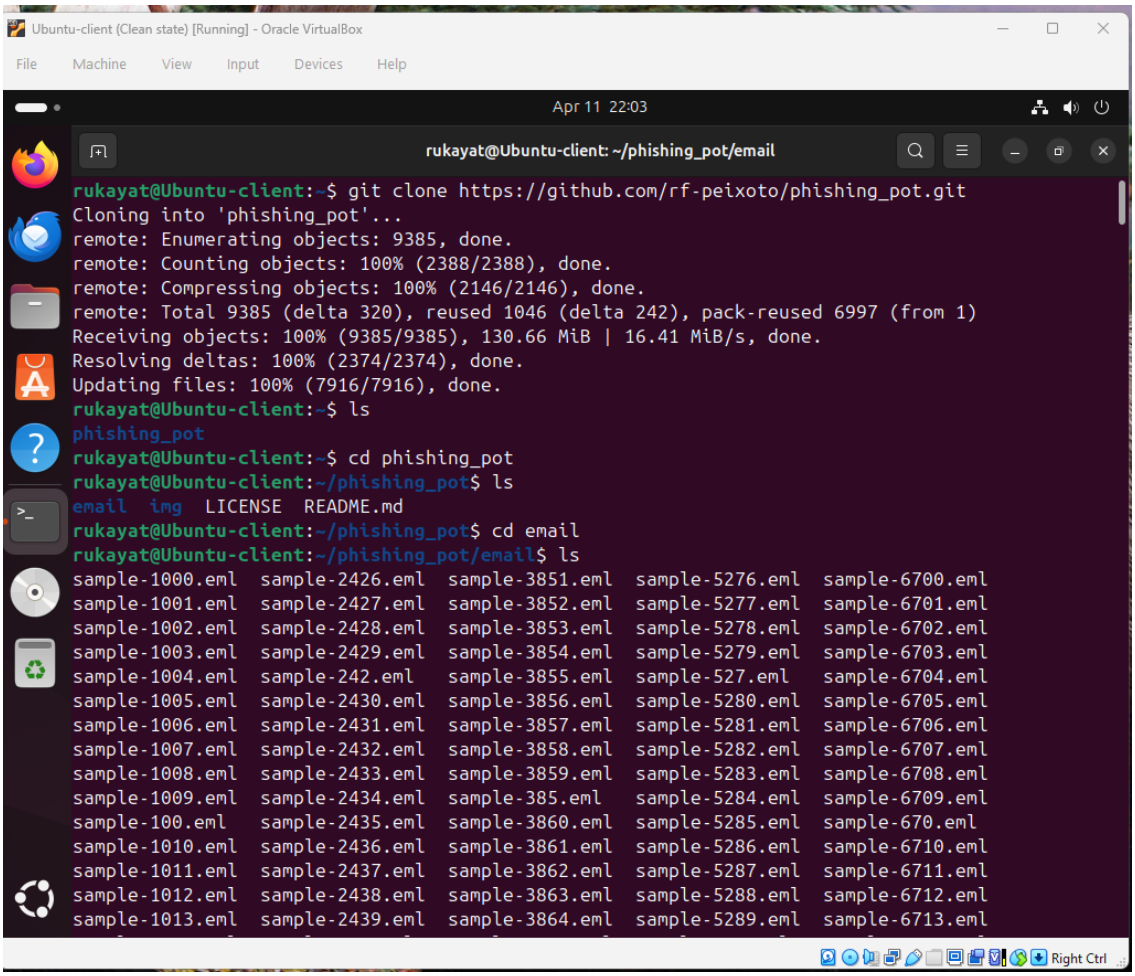
The analysis was conducted inside an Oracle VirtualBox virtual machine running Ubuntu 24 LTS. The environment was intentionally isolated to prevent any malicious payloads from executing on live infrastructure.

| Component | Details |
|---|---|
| VM Platform | Oracle VirtualBox |
| Guest OS | Ubuntu 24 LTS (Clean State) |
| Email Client | Mozilla Thunderbird 140.9.1esr (via snap) |
| Text Editor | Mousepad (raw .eml inspection) |
| IP Reputation Tool | AbuseIPDB (abuseipdb.com) |
| Initial User (root) | root@Ubuntu-client |
| Secondary User | rukayat@Ubuntu-client / admin@Ubuntu-client |

## 2.2 Dataset Acquisition

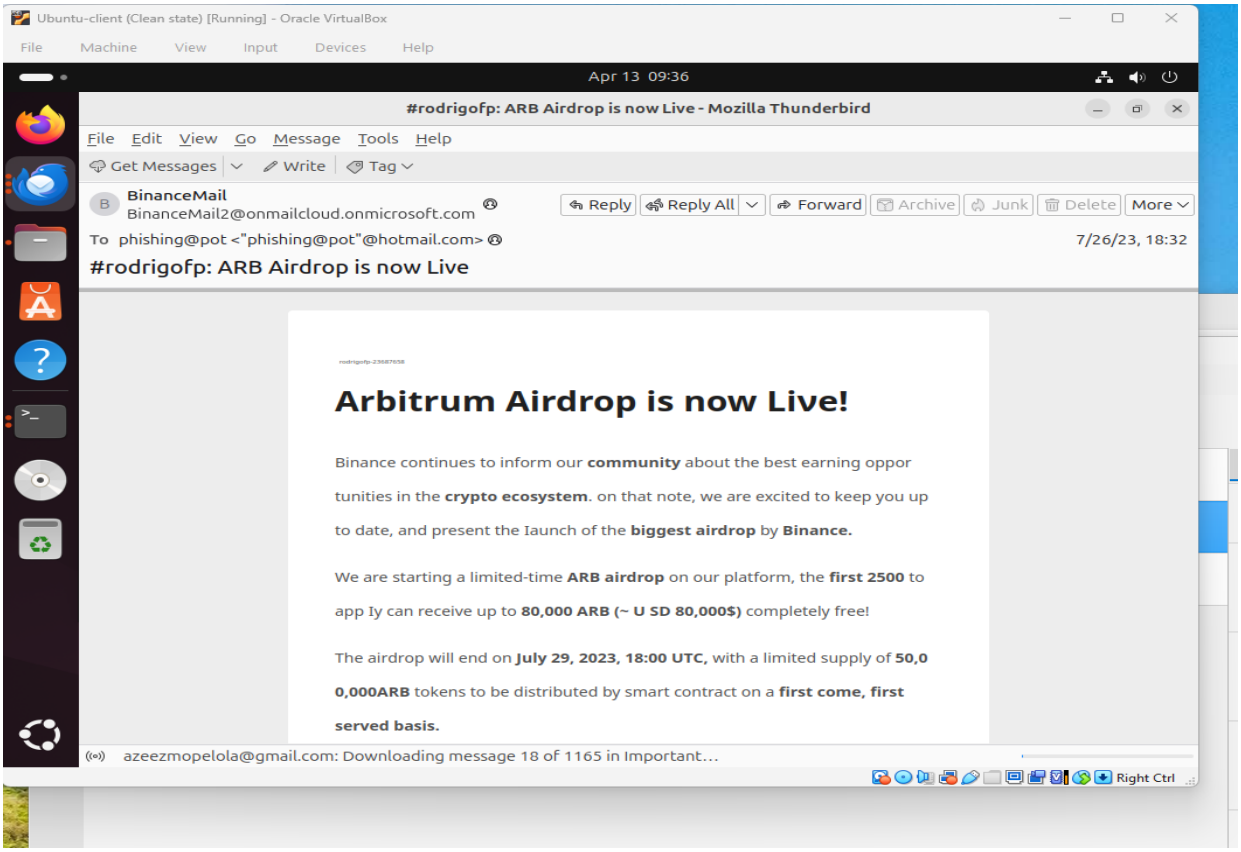
The phishing email corpus was cloned from the public GitHub repository rf-peixoto/phishing_pot using Git. The repository contained 9,385 objects (130.66 MiB). After cloning, the working directory was navigated to phishing_pot/email/, which contained thousands of .eml sample files.

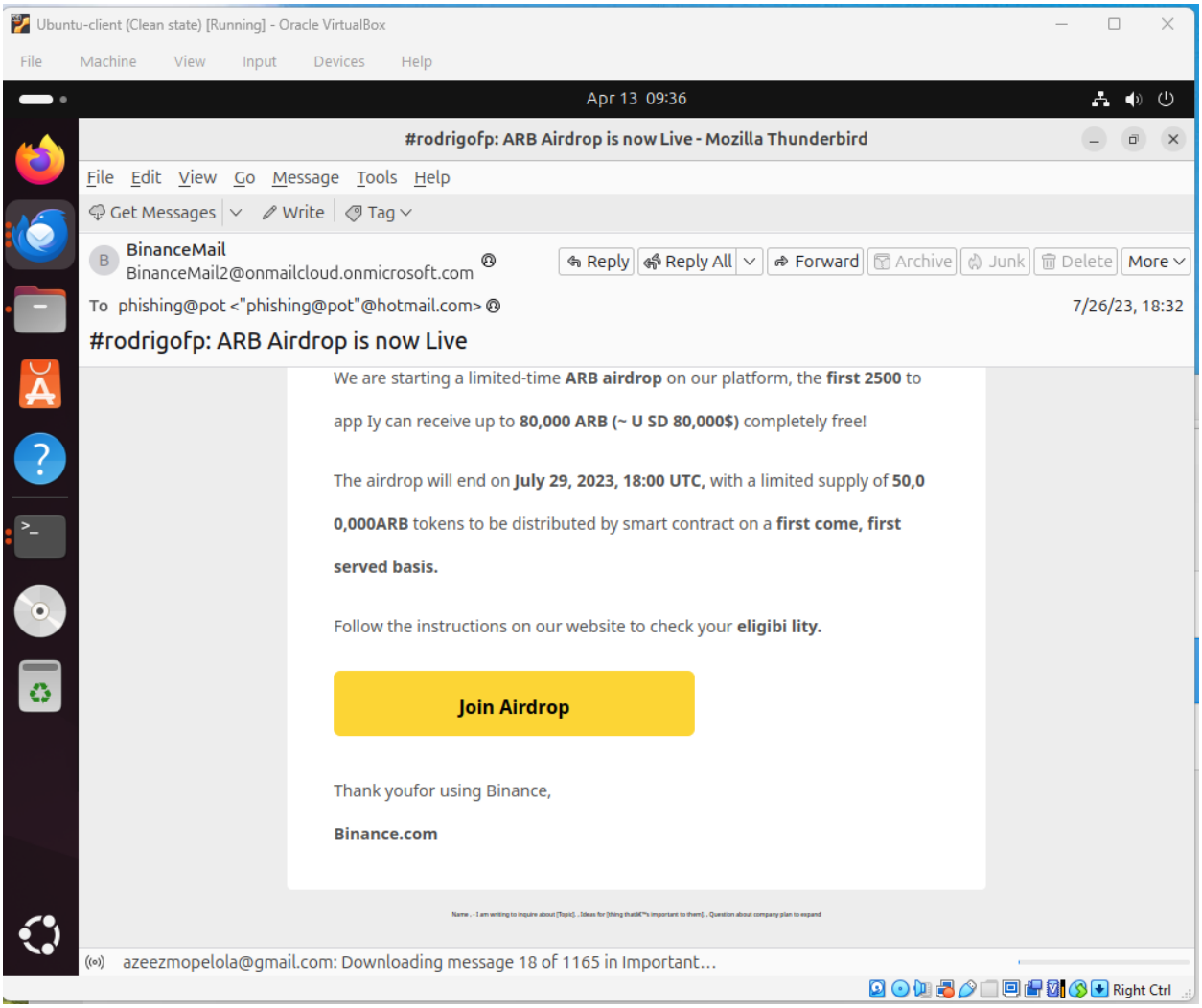
- Repository: https://github.com/rf-peixoto/phishing_pot.git
- Clone command: git clone https://github.com/rf-peixoto/phishing_pot.git
- Target email: sample-996.eml
- File location: ~/phishing_pot/email/sample-996.eml




# 3. Email Overview

## 3.1 Email Metadata






| Field | Value |
|---|---|
| From (Display) | BinanceMail |
| From (Address) | BinanceMail2@onmailcloud.onmicrosoft.com |
| To | "phishing@pot" <phishing@pot@hotmail.com> |
| Subject | #rodrigofp: ARB Airdrop is now Live |
| Date | Wed, 26 Jul 2023, 18:32:33 +0000 |
| Message-ID | <WA0P291MB008013089869A243AC63A626C000A@WA0P291MB0080.POLP291.PROD.OUTLOOK.COM> |
| Thread-Topic | #rodrigofp: ARB Airdrop is now Live |
| Accept-Language | en-US |
| Content-Language | en-US |

### 3.2 Email Body Summary

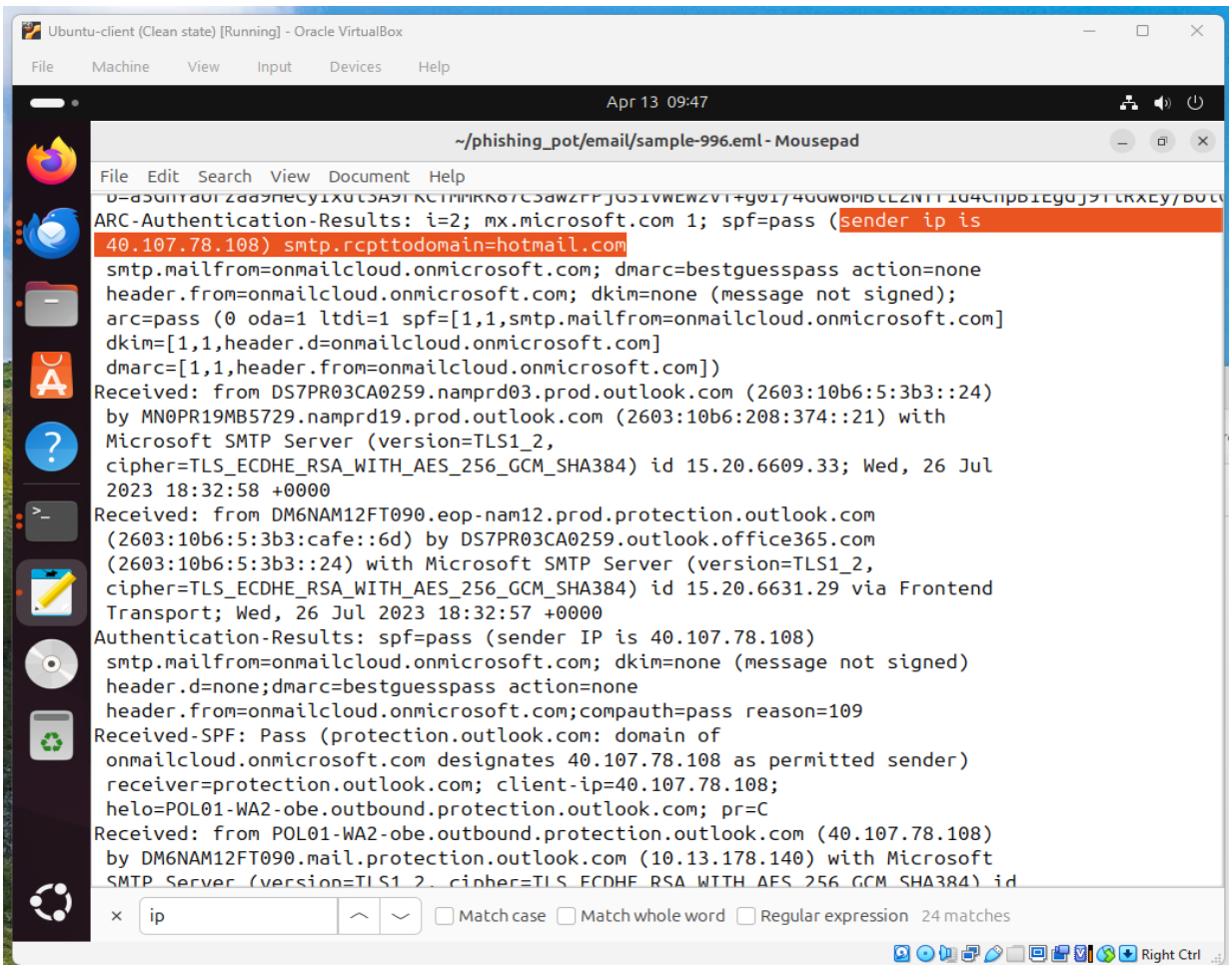
The rendered email body presented in Thunderbird claimed to be from Binance notifying the recipient of an Arbitrum (ARB) token airdrop. Key social engineering elements included:

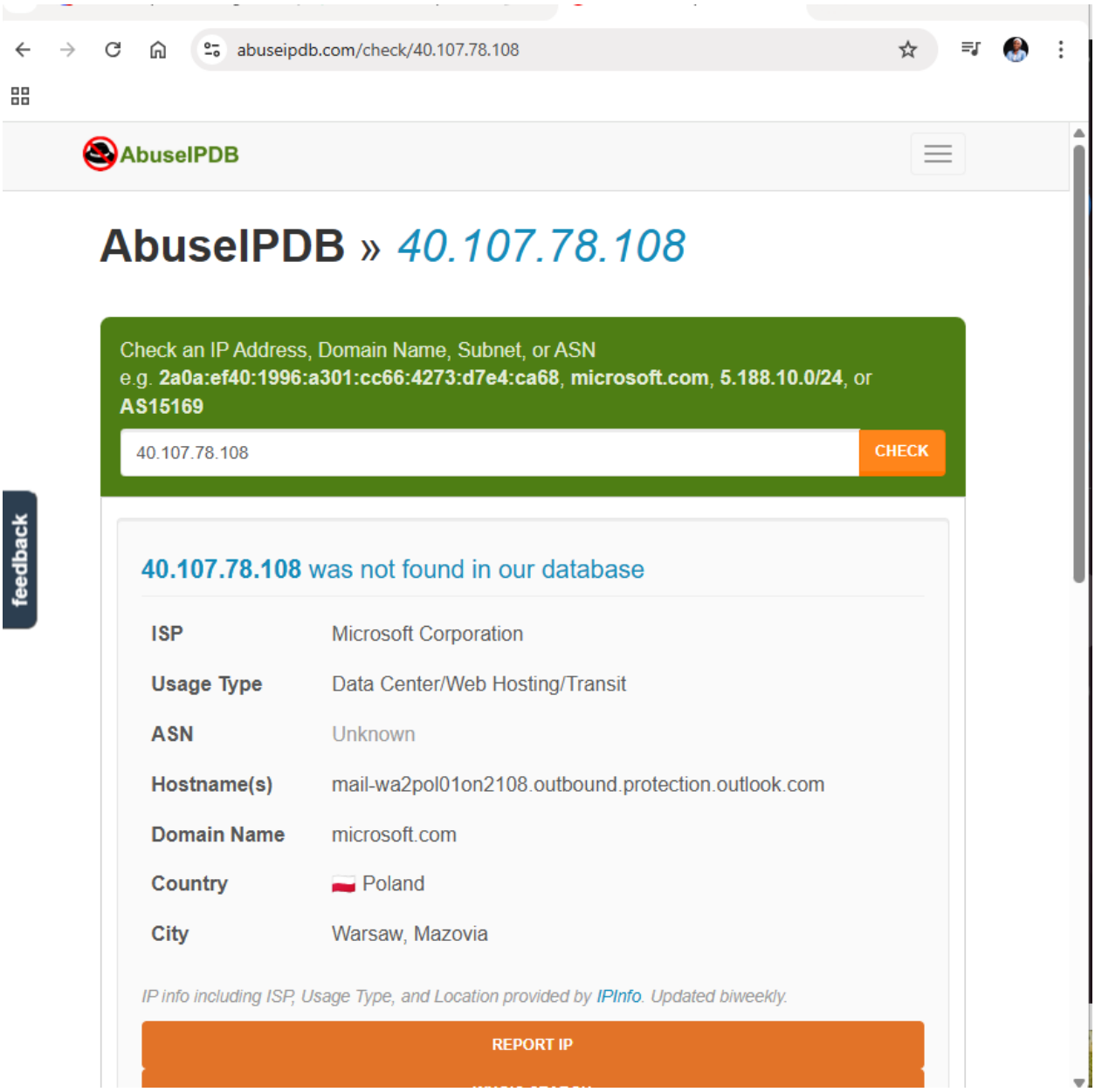
- Urgency framing: Limited-time offer expiring July 29, 2023 at 18:00 UTC
- Financial incentive: First 2,500 applicants could receive up to 80,000 ARB (~USD $80,000)
- Total supply claim: 50,000,000 ARB tokens distributed by smart contract
- Call to action: A prominent yellow 'Join Airdrop' button linking to a malicious URL
- Impersonation: Signed off as 'Binance.com' with official-looking branding

## 4. Email Header Analysis

### 4.1 Sender IP Address

The sending IP address identified in the email headers was 40.107.78.108. This IP was cross-referenced with AbuseIPDB for threat intelligence enrichment.





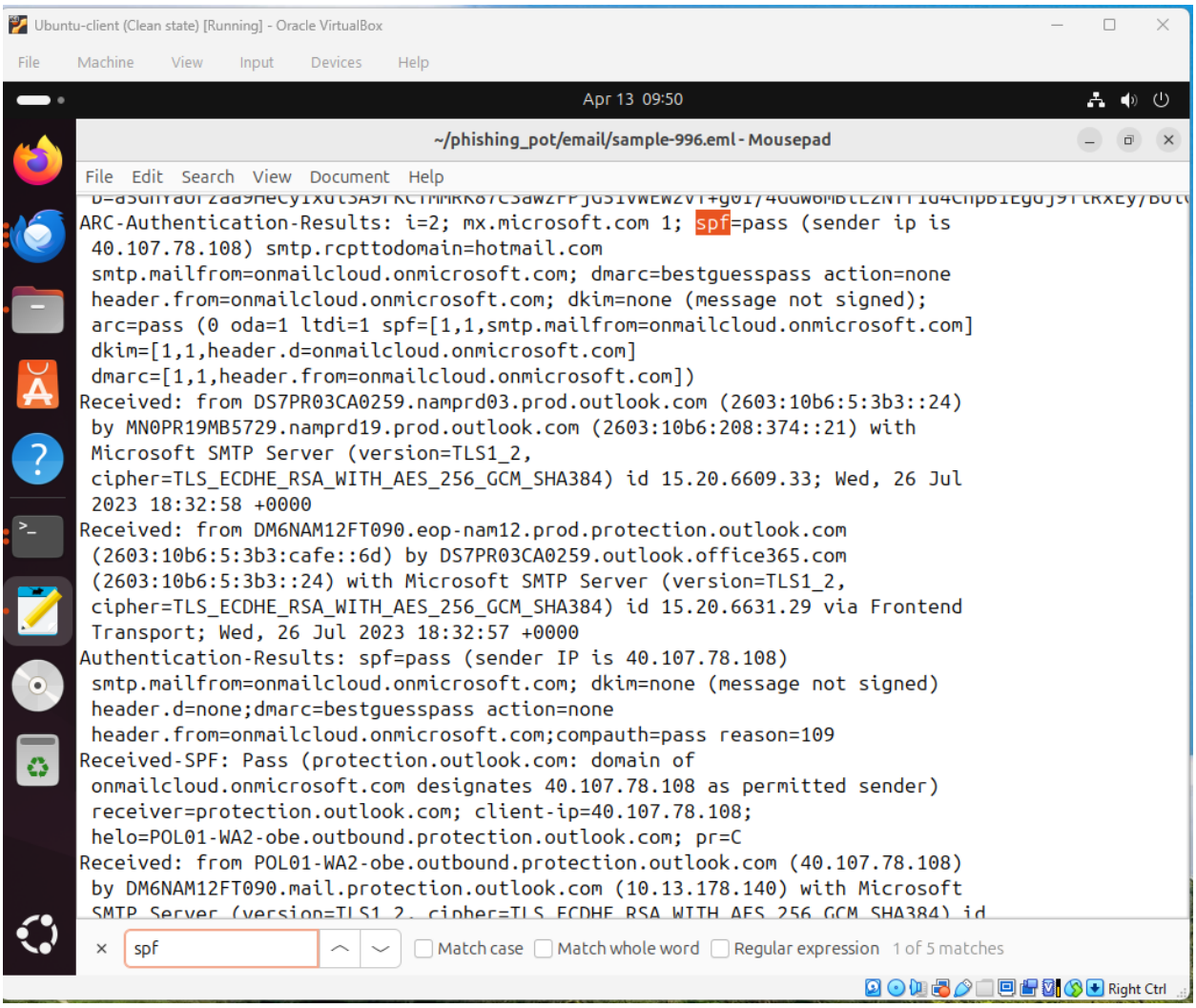

| Attribute | Value |
|---|---|
| Sending IP | 40.107.78.108 |
| ISP | Microsoft Corporation |
| Usage Type | Data Center / Web Hosting / Transit |
| Hostname | mail-wa2pol01on2108.outbound.protection.outlook.com |
| Domain | microsoft.com |
| Country | Poland |
| City | Warsaw, Mazovia |

| Attribute | Value |
|---|---|
| AbuseIPDB Status | Not found in database (no prior abuse reports) |
| ASN | Unknown |

The IP belongs to Microsoft's outbound Office 365 / Outlook mail relay infrastructure, indicating the attacker leveraged a Microsoft-hosted tenant (onmailcloud.onmicrosoft.com) to send the phishing email — a common tactic to exploit trusted sending infrastructure and bypass basic IP reputation filters.

## 4.2 SPF (Sender Policy Framework)

SPF authentication was evaluated by searching for 'spf' within the raw .eml header (1 of 5 matches for initial result). Findings:

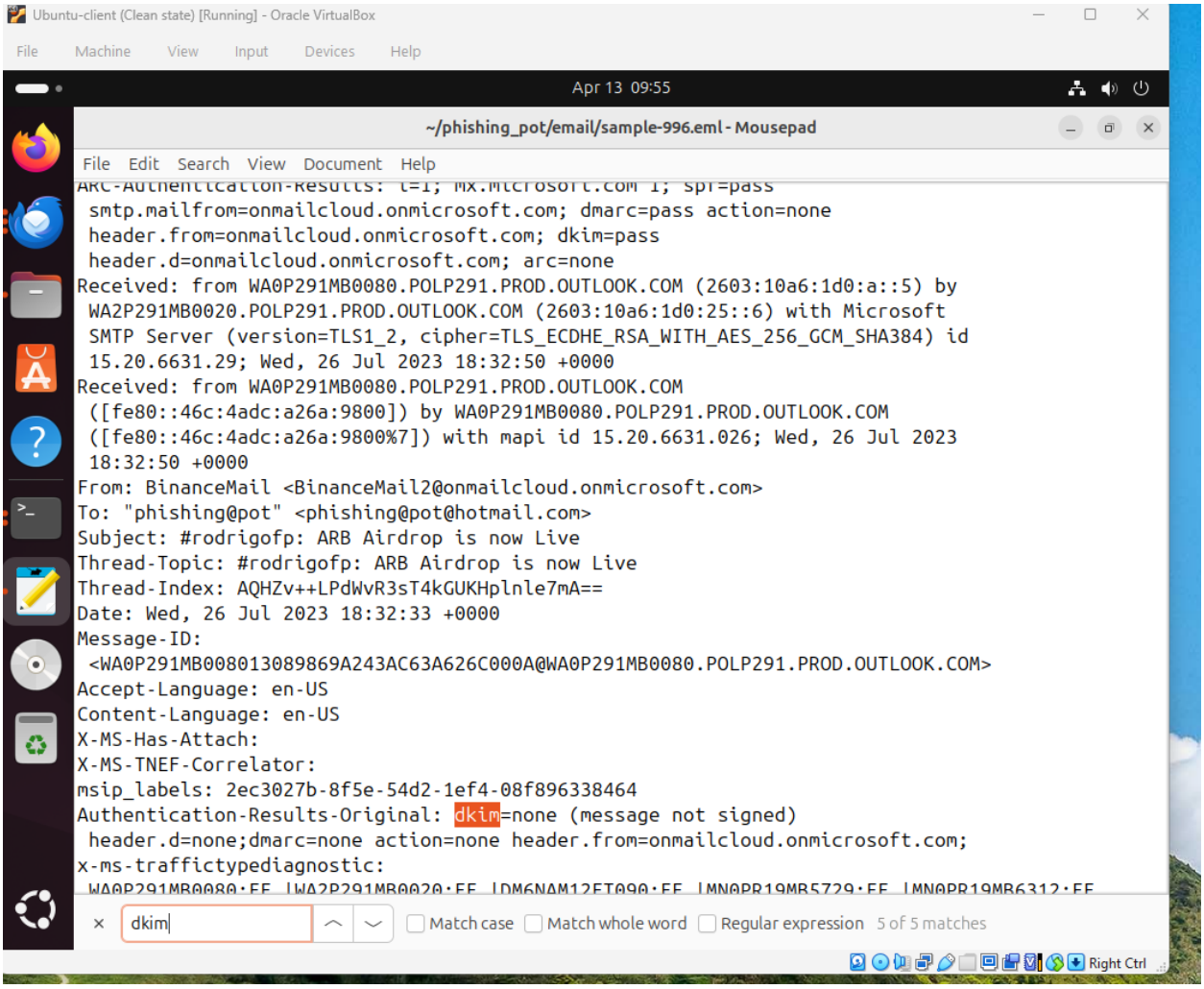


| Check | Result |
|---|---|
| SPF Result | PASS |
| Sender IP Evaluated | 40.107.78.108 |
| smtp.mailfrom | onmailcloud.onmicrosoft.com |
| Receiving MTA | protection.outlook.com |
| Notes | onmailcloud.onmicrosoft.com designates 40.107.78.108 as permitted sender |

SPF passed because the attacker used a legitimate Microsoft-hosted tenant (onmailcloud.onmicrosoft.com) as the sending domain, which is within the permitted SPF range for Microsoft's infrastructure. This demonstrates how abusing legitimate cloud services can circumvent SPF controls.

## 4.3 DKIM (DomainKeys Identified Mail)

DKIM authentication was assessed via header search (5 of 5 matches). Findings across multiple header sections:

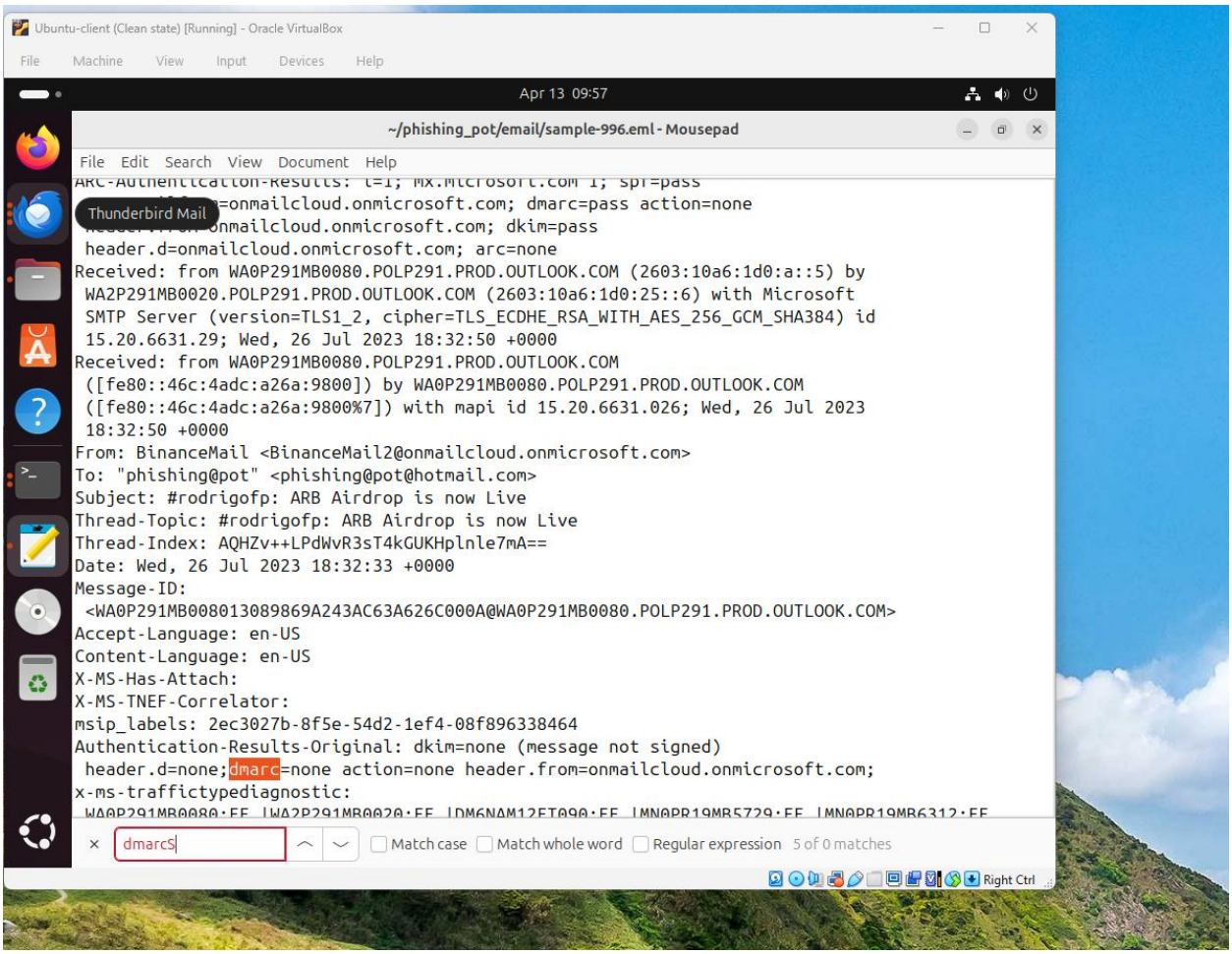



| Header Section | DKIM Result |
|---|---|
| Authentication-Results-Original | dkim=none (message not signed) |
| ARC-Authentication-Results i=1 | dkim=pass; header.d=onmailcloud.onmicrosoft.com |
| ARC-Authentication-Results i=2 | dkim=none (message not signed) |
| smtp.mailfrom check | dkim=none |
| Overall Assessment | Unsigned at origin; ARC chain added by Microsoft relay |

The message was not DKIM-signed by the originating sender, which is a significant red flag. The ARC (Authenticated Received Chain) entries were added by Microsoft's mail relay infrastructure, not by the attacker. Absence of DKIM signing means the email body and headers cannot be verified as unaltered since sending.

## 4.4 DMARC (Domain-based Message Authentication)

DMARC policy evaluation results (searched as 'dmarc', 5 of 0 matches for 'dmarcS' — confirming no DMARC strict policy found):



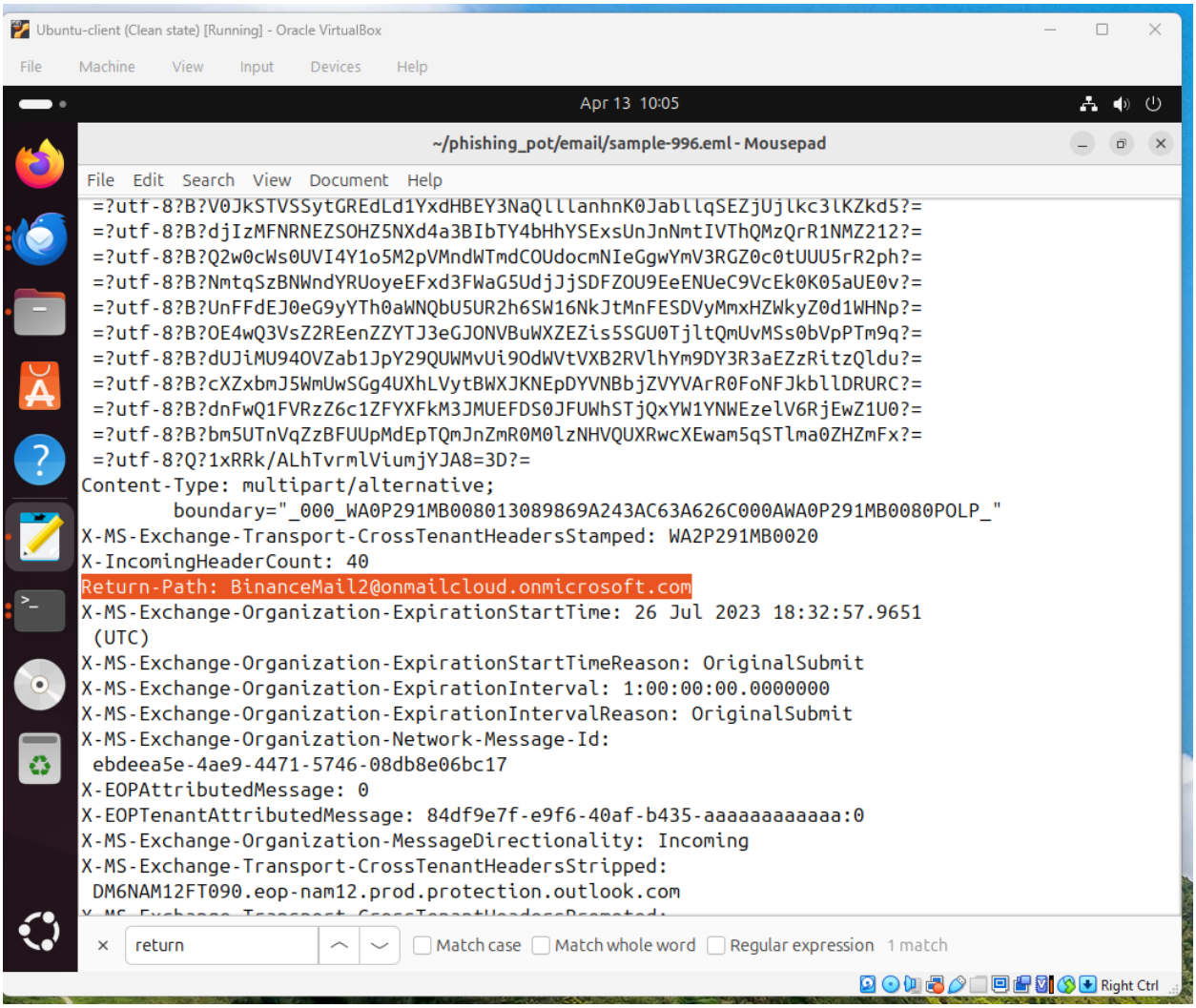

| Attribute | Value |
|---|---|
| DMARC Result (Original) | dmarc=none action=none |
| header.from | onmailcloud.onmicrosoft.com |
| ARC Result i=1 | dmarc=pass action=none |
| Effective Policy | bestguesspass (no explicit DMARC policy published) |
| Risk | No enforced reject/quarantine policy on sender domain |

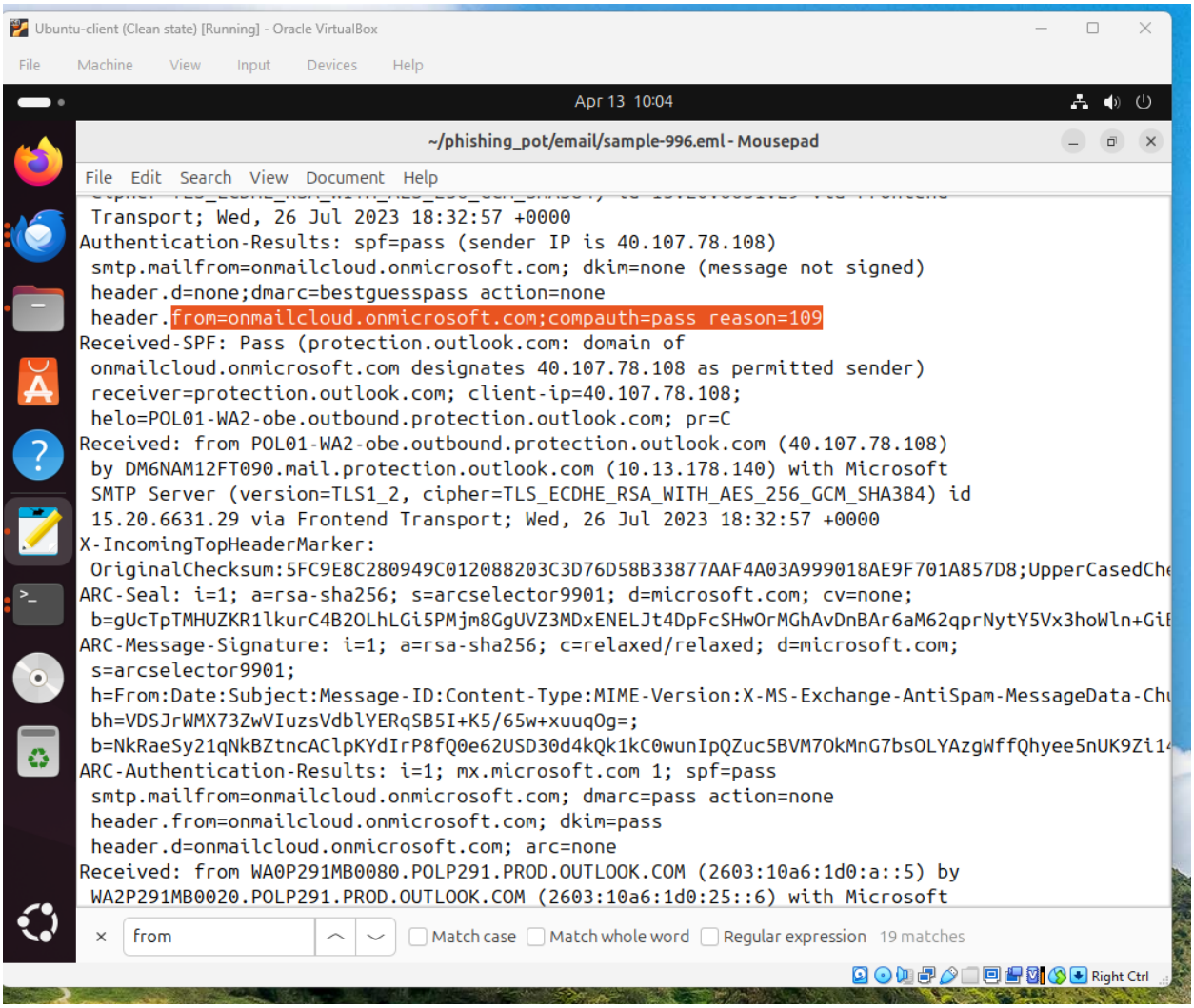
The sending domain onmailcloud.onmicrosoft.com had no published DMARC policy ('dmarc=none'), meaning even if authentication failed, no action (quarantine or rejection) would

be enforced. This is a common characteristic of freshly registered or disposable Microsoft tenant domains used by threat actors.

## 4.5 Return-Path Analysis

The Return-Path header confirmed the bounce address for the message:


Ubuntu-client (Clean state) [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Apr 13 10:05
~/phishing_pot/email/sample-996.eml - Mousepad
File Edit Search View Document Help
=?utf-8?B?V0JkSTVSSytGREdLd1YxdHBEY3NaQlllanhnK0JabllqSEZjUjlkc3lKZkd5?=
=?utf-8?B?djIzMFNRNEZSOHZ5NXd4a3BIbTY4bHhYSExsUnJnNmtIVThQMzQrR1NMZ212?=
=?utf-8?B?Q2w0cWs0UVI4Y1o5M2pVMndWTmdCOUdocmNIeGgwYmV3RGZ0c0tUUU5rR2ph?=
=?utf-8?B?NmtqSzBNWndYRUoyeEFxd3FWaG5UdjJjSDFZOU9EeENUeC9VcEk0K05aUE0v?=
=?utf-8?B?UnFFdEJ0eG9yYTh0aWNQbU5UR2h6SW16NkJtMnFESDVyMmxHZWkyZ0d1WHNp?=
=?utf-8?B?OE4wQ3VsZ2REenZZYTJ3eGJONVBuWXZEZis5SGU0TjltQmUvMSs0bVpPTm9q?=
=?utf-8?B?dUJiMU94OVZab1JpY29QUWMvUi9OdWVtVXB2RVlhYm9DY3R3aEZzRitzQldu?=
=?utf-8?B?cXZxbmJ5WmUwSGg4UXhLVytBWXJKNEpDYVNBbjZVYVArR0FoNFJkbllDRURC?=
=?utf-8?B?dnFwQ1FVRzZ6c1ZFYXFkM3JMUEFDS0JFUWhSTjQxYW1YNWEzelV6RjEwZ1U0?=
=?utf-8?B?bm5UTnVqZzBFUUpMdEpTQmJnZmR0M0lzNHVQUXRwcXEwam5qSTlma0ZHZmFx?=
=?utf-8?Q?1xRRk/ALhTvrmlViumjYJA8=3D?=
Content-Type: multipart/alternative;
boundary="_000_WA0P291MB008013089869A243AC63A626C000AWA0P291MB0080POLP_"
X-MS-Exchange-Transport-CrossTenantHeadersStamped: WA2P291MB0020
X-IncomingHeaderCount: 40
Return-Path: BinanceMail2@onmailcloud.onmicrosoft.com
X-MS-Exchange-Organization-ExpirationStartTime: 26 Jul 2023 18:32:57.9651
(UTC)
X-MS-Exchange-Organization-ExpirationStartTimeReason: OriginalSubmit
X-MS-Exchange-Organization-ExpirationInterval: 1:00:00:00.0000000
X-MS-Exchange-Organization-ExpirationIntervalReason: OriginalSubmit
X-MS-Exchange-Organization-Network-Message-Id:
ebdeea5e-4ae9-4471-5746-08db8e06bc17
X-EOPAttributedMessage: 0
X-EOPTenantAttributedMessage: 84df9e7f-e9f6-40af-b435-aaaaaaaaaaaa:0
X-MS-Exchange-Organization-MessageDirectionality: Incoming
X-MS-Exchange-Transport-CrossTenantHeadersStripped:
DM6NAM12FT090.eop-nam12.prod.protection.outlook.com
return
Match case
Match whole word
Regular expression
1 match
Right Ctrl




- Return-Path: BinanceMail2@onmailcloud.onmicrosoft.com

The Return-Path matches the smtp.mailfrom domain (onmailcloud.onmicrosoft.com), which is consistent with a controlled sender domain used to pass SPF. There is no alignment with any legitimate Binance domain (binance.com), confirming domain impersonation.

## 4.6 Mail Routing & Received Headers

The email traversed through Microsoft's Outlook/Exchange infrastructure as follows:

| Hop | Server | Timestamp |
|---|---|---|
| 1 (Origin) | WA0P291MB0080.POLP291.PROD.OUTLOOK.COM | 26 Jul 2023 18:32:50 +0000 |
| 2 | WA2P291MB0020.POLP291.PROD.OUTLOOK.COM | 26 Jul 2023 18:32:50 +0000 |
| 3 | DM6NAM12FT090.eop-nam12.prod.protection.outlook.com | 26 Jul 2023 18:32:57 +0000 |
| 4 | DS7PR03CA0259.outlook.office365.com | 26 Jul 2023 18:32:57 +0000 |

| Hop | Server | Timestamp |
|---|---|---|
| 5 (Delivery) | MN0PR19MB5729.namprd19.prod.outlook.com | 26 Jul 2023 18:32:58 +0000 |

# 5. Malicious URL Analysis

## 5.1 Embedded URL

The 'Join Airdrop' button within the email body contained an embedded tracking/redirect URL:

`https://click.pstmrk.it/3s/sweedbuy.com%2Fblog%2F/ahc/k_CuAQ/AQ/44a54f89-410d-4729-b21c-32c30d6eb945/1/qOoKiS9V1s?/23687658rodrigofp`

## 5.2 URL Breakdown

| Component | Value | Notes |
|---|---|---|
| Tracker Domain | click.pstmrk.it | Postmark click-tracking service — abused for URL obfuscation |
| Destination Domain | sweedbuy.com | Likely fraudulent/spoofed crypto platform |
| Path | /blog/ahc/k_CuAQ/... | Encoded redirect with unique victim tracking ID |
| Tracking ID | 44a54f89-410d-4729-b21c-32c30d6eb945 | Per-victim unique identifier (GUID) |
| Campaign Tag | 23687658rodrigofp | Likely attacker campaign/affiliate identifier |

When the URL was accessed during analysis, the browser returned HTTP 404 Not Found, indicating the phishing infrastructure had been taken offline (likely due to the 2023 campaign expiry). The use of a legitimate email delivery service (Postmark) for click tracking is a deliberate obfuscation technique to evade URL reputation filters.

# 6. Indicators of Compromise (IOCs)

| Type | Value | Confidence |
|---|---|---|
| Sender Email | BinanceMail2@onmailcloud.onmicrosoft.com | High |
| Sending IP | 40.107.78.108 | High |
| Return-Path Domain | onmailcloud.onmicrosoft.com | High |
| Redirect URL | click.pstmrk.it/3s/sweedbuy.com%2Fblog%2F/... | High |
| Destination Domain | sweedbuy.com | High |

| Type | Value | Confidence |
|---|---|---|
| Campaign Tag | 23687658rodrigofp | Medium |
| Victim GUID | 44a54f89-410d-4729-b21c-32c30d6eb945 | Medium |
| Subject Line Pattern | #rodrigofp: ARB Airdrop is now Live | Medium |
| Message-ID Domain | WA0P291MB0080.POLP291.PROD.OUTLOOK.COM | Low |

### 7 Key Evasion Techniques Observed

- Trusted Infrastructure Abuse: Sending email via Microsoft-hosted tenant (onmailcloud.onmicrosoft.com) to pass SPF and avoid IP reputation blocks
- Click-Tracking Obfuscation: Using Postmark's legitimate tracking domain (click.pstmrk.it) to hide the actual malicious destination URL
- No DKIM Signing: Avoided DKIM to reduce forensic traceability to a specific signing key
- No DMARC Policy: Chose a tenant domain with no published DMARC enforcement policy
- Social Engineering: Cryptocurrency airdrop theme exploiting FOMO (Fear of Missing Out) and financial greed
- Urgency & Scarcity: Hard deadline and limited supply claims to pressure immediate action

## 8. Summary of Findings

| Authentication Check | Result | Risk Level |
|---|---|---|
| SPF | PASS (via Microsoft tenant) | Medium — passes due to cloud abuse |
| DKIM | NONE (not signed) | High — cannot verify message integrity |
| DMARC | NONE (no policy published) | High — no enforcement action possible |
| ARC | Pass (relay chain only) | Low — added by relay, not sender |
| IP Reputation | Clean (Microsoft infrastructure) | Medium — trusted IP misused |
| URL Safety | Malicious (inactive at time of analysis) | Critical |

# 9. Recommendations

## 9.1 For Email Security Teams

- Enforce DMARC with a reject or quarantine policy on organisational domains to prevent domain impersonation
- Implement DKIM signing on all outbound mail to provide cryptographic message integrity verification
- Deploy URL sandboxing and click-time URL rewriting to detect obfuscated redirect chains
- Configure mail gateway rules to flag emails from onmicrosoft.com tenants impersonating financial institutions
- Subscribe to threat intelligence feeds for newly registered or disposable Microsoft tenants

## 9.2 For End Users

- Verify the sender's actual email address, not just the display name — 'BinanceMail' is not binance.com
- Be sceptical of unsolicited cryptocurrency airdrop or financial reward emails
- Do not click links in emails; navigate directly to official websites
- Report suspicious emails to your security team or use the Junk/Phishing flag in email clients

# 10. Conclusion

The analysis of sample-996.eml confirms it as a phishing email employing cryptocurrency-themed social engineering to deceive victims into visiting a malicious web portal. The attacker demonstrated a sophisticated understanding of email authentication mechanisms, deliberately choosing a Microsoft-hosted tenant to pass SPF checks while exploiting the absence of DKIM signing and DMARC enforcement.

The use of a legitimate click-tracking service (Postmark) to obfuscate the final destination URL is a notable evasion technique that highlights the evolving nature of phishing infrastructure. By the time of analysis in April 2026, the phishing page had been taken offline, consistent with the time-limited nature of the July 2023 campaign.

This case underscores the importance of layered email security controls — particularly DMARC enforcement and URL inspection — as well as ongoing user awareness training to counter social engineering attacks targeting cryptocurrency users.